Prof. Dr. Mario Boßlau

WS 2025/26

Digital Management

Gamification – Group activity

Ahmad, Nur Hidayah Binti

Matr. Nr. 335033

@hs-pforzheim.de

Jin, Chaeyeon

Matr. Nr. 334787

jinchaey@hs-pforzheim.de

Lupi, Claribel Crystal Lupi

Matr. Nr.

@hs-pforzheim.de

Yagui Nishii, Valeria

Matr. Nr 334789

yaguinis@hs-pforzheim.de

Submission date:14.01.2026

IT Security Gamification:
Hacker & Defender Simulation

"Know your enemy and know yourself, and you will never be defeated"

Content

Introduction 3
1. Educational Objectives 4
IT Security Concepts 4
2. Game Overview & Scenario 7
3. Level Analysis 7
Level 1: Hash Breaker (Password Cracking Analysis) 7
Level 2: Phishing Designer (Social Engineering Simulation) 8
Level 3: Virtual Desktop (Foothold Simulator) 8
Level 4: Escalation Sequence (Privilege Escalation Analysis) 9
Level 5: Data Discovery & Protection (Governance) 9
4. Solution and Answer Key 10
Resources 11

Introduction

In the Digital Business world, a single security breach can destroy customer trust, create legal issues, cost millions in damages, and end careers. Therefore, this simulation game was developed to help students understand the fundamental IT security concepts and reinforce their strategic thinking and decision-making regarding security issues.

In this game, the player will simulate to be a new intern in a (fictional) hacker group, whose task is to hack a small company with bad cybersecurity measures. This will help the student understand how attackers work and how they apply different techniques to deploy a cybersecurity attack.

1. Educational Objectives

- **Mastering fundamental IT security concepts**: Gain intuitive understanding of core cybersecurity principles and terminology through interactive simulation.

- **Establishing attacker-centric defense strategies**: Learn the logical flow of a cyberattack, from initial penetration to data exfiltration. By performing actual hacking techniques (cracking, phishing, privilege escalation), learners realize the necessity of defensive mechanisms.

- **Establishing defender-centric response strategies**: Develop practical skills in Incident Response by prioritizing assets based on criticality and executing immediate mitigation steps like network isolation and log analysis.

- **Strengthening practical security governance**: Foster a managerial mindset that evaluates data value and applies appropriate security policies, moving beyond simple technical implementation.

IT Security Concepts

These are some of the IT security concepts student will learn during the game:

- **Hash Password:** Transforms a user's password into a fixed-length string of mixed-up characters that cannot be easily reversed or deciphered. When someone creates an account on any platform, their password is typically run through a hash password function before being stored in the service's database. Hashing is nearly impossible to revert (*What Is Password Hashing?* | Bitwarden, n.d.; NordPass, n.d.).

- **Dictionary Attack:** It is a password-cracking technique where an attacker uses a pre-made list of common passwords or words (called a dictionary) and systematically tries them to guess a password. It tries words and phrases that are likely to be used by people due to their familiarity (GeeksforGeeks, 2025; JumpCloud, 2025).

- **Domain spoofing:** It is a cyberattack technique where criminals impersonate a legitimate organization's domain name to deceive users. They make fraudulent emails or websites appear as if they originate from your trusted company domain, tricking victims into revealing sensitive data, downloading malware, or transferring money (*A Complete Guide to Domain Spoofing - Resilience*, 2025)

- **Social engineering:** Social engineering is an attempt to manipulate and deceive someone into revealing sensitive information (e.g., a password, financial details) or performing actions that compromise their security and that can be used to attack systems or networks. It relies on psychology and human behavior, rather than technical know-how. The attacker often poses as a trusted person or source in order to gain the victim's trust (Scarfone et al., 2008; *Cybersecurity: Social Engineering*, 2025).

- **Phishing:** It is form of digital social engineering, where attackers attempt to steal personal and confidential information such as credit card numbers and passwords. Phishing uses authentic-looking emails to request information or direct users to a false Web site to collect information (Scarfone et al., 2008).

- **Trojan:** It is a technique where hackers disguise their malware as a useful program and hope that users will install it for themselves Once it is unsuspectingly installed, attackers are able to perform actions that the legitimate user can (e.g., exporting or modifying information or deleting files) (*Trojans: How Can I Identify Malware in Disguise?*, n.d.; Advantex Network Solutions Limited, 2025)

- **Backdoor:** It is a secret access point to a computer system, software or network that makes it possible to avoid the usual authentication and security mechanisms (facilitate unauthorized access). A backdoor can be deliberately installed by developers to facilitate maintenance work or by attackers to gain unauthorized access (*Backdoor*, n.d.),

- **Privileged escalation:** It is an attack to gain unauthorized access and administrative rights to a system. Attackers typically start with limited access and then systematically work to upgrade to an all-access administrative pass (*Privilege Escalation Attacks & How to Defend Against Them | ScreenConnect*, n.d.).

- **Keylogger:** It is a type of monitoring software or hardware that records every keystroke a user makes on their keyboard. The data is then stored locally or sent to a remote server. Hackers often use keyloggers to steal passwords, credit card information, or other personal data (*Keylogger*, n.d.).

- **Data Exfiltration:** It refers to the unauthorized transfer of data from a company's network (*What Is Data Exfiltration? | Bitwarden*, n.d.).

- **Logging & monitoring:**
    - **Logging** is the process of collecting data that represents specific information (e.g., activities, events, error conditions, general status of an information system or network) (*Network Security Logging and Monitoring - ITSAP.80.085 - Canadian Centre for Cyber Security*, 2022)
    - **Monitoring** is the process of observing data collected from multiple sources, including network devices, servers, applications, databases, and other IT infrastructure components. The purpose is to look for indications of known attacks, unusual changes in system behavior or unauthorized security-related activities (*Network Security Logging and Monitoring - ITSAP.80.085 - Canadian Centre for Cyber Security*, 2022).

2. Game Overview & Scenario

- **Overview**: A web-based interactive simulation consisting of 5 missions designed to experience the core principles of cyber-attack and defense.

- **Scenario**: Players are deployed into a simulated penetration test against the company. The journey starts with recovering leaked hashed passwords, followed by an internal breach via social engineering. After gaining system control, players exfiltrate data and finally transition to a defender's role to establish a governance framework for asset protection.

3. Level Analysis

Level 1: Hash Breaker (Password Cracking Analysis)

- **Content**: A dictionary attack simulation to recover original passwords from leaked database hashes.

- **Gameplay**:
  1. Review the 4 leaked employee password hashes.
  2. Analyze hints from the "AI Analysis Hint" section.
  3. Match the hints against the "Password Dictionary" to find the corresponding plaintext.
  4. Progress by successfully cracking all employee passwords.

- **Key Concepts**: One-way hash functions, dictionary attacks, weak password patterns.

- **Learning Outcome**: Understand how simple word combinations are vulnerable to hash-matching and learn the principles of data protection.

Level 2: Phishing Designer (Social Engineering Simulation)

- **Content**: Design a convincing phishing email from an attacker's perspective to understand social engineering.

- **Gameplay**:
  1. **Compose**: Select from 5 components: sender, subject, body, attachment, and trust elements.
  2. **Analyze**: Monitor "Live Analysis" metrics: convincability, suspicion level, and likelihood to click.
  3. **Optimize**: Complete the email by finding the most lethal combination that minimizes suspicion while maximizing clicks.

- **Key Concepts**: Social engineering (psychological manipulation), phishing anatomy, vulnerability metrics.

- **Learning Outcome**: Develop the ability to immediately identify suspicious patterns in real-world digital communications.

Level 3: Virtual Desktop (Foothold Simulator)

- **Content**: Categorize target assets and defensive actions following a Trojan infection via phishing.

- **Gameplay**:
  1. **Categorize**: Click icons on the "Compromised Workstation" to designate them.
  2. **Cycle**: None → Attacker Target (Red) → Defender Action (Green) → Reset.
  3. **Constraints**: Strategic selection is required within limits (max 3 targets, 4 actions).

- **Key Concepts**: Foothold & post-breach threats, Incident response procedures.

- **Learning Outcome**: Identify high-value assets and memorize Standard Operating Procedures (SOP) for breach mitigation.

Level 4: Escalation Sequence (Privilege Escalation Analysis)

- **Content**: Arrange the logical sequence of an attack from entry to data exfiltration.

- **Gameplay**:
  1. Review 4 randomized attack actions.
  2. Drag or use arrows to sort them into a logical sequence.

- **Key Concepts**: Privilege escalation, keylogger, backdoor, and exfiltration

- **Learning Outcome**: Comprehend the structured flow of advanced attacks and develop step-by-step monitoring strategies.

Level 5: Data Discovery & Protection (Governance)

- **Content**: Evaluate asset sensitivity and apply optimized security controls from a managerial perspective.

- **Gameplay**:
  1. **Classification**: Assign a tier (Confidential, Internal, or Public).
  2. **Control:** Match tiers with tools (Encryption, Access Control, Multi-factor Auth, or Monitoring).

- **Key Concepts**: Data governance, classification frameworks, technical security controls.

- **Learning Outcome**: Gain the ability to make strategic security decisions and establish practical protection measures based on business risk.

4. Solution and Answer Key

Level	Solution
Level 1	Names and passwords change every round, so there is no fixed solution. To find the best solution, the player must look at the "**AI Analysis Hint**" (Target and Analysis) and based on the information provided, choose the password that fits the best, and run the hash. Another hint to find the right answers, is to look at the "**Target Hash**" and "**Guess Hash**". If both hashes match, that is the right password.
Level 2	In this level, there are multiple solutions that can unlock the next level. Some of them have been provided below: **Sender:** security@corp-it-update.com / **Subject:** Required: Security Update (Use official-looking trust logos) / **Body:** Professional urgent message / **Attachment:** Workstation_Patch_v2.04.exe / **Trust:** IT Manager signature block **Sender:** security@corp-it-update.com / **Subject:** URGENT: Your Account Will Be Suspended/ **Body:** Professional urgent message / **Attachment:** Q4_Security_Compliance.pdf.exe / **Trust:** Internal reference ID **Sender:** security@corp-it-update.com / **Subject:** Required: Security Update for Your Workstation **/ Body:** Professional urgent message / **Attachment:** Q4_Security_Compliance.pdf.exe / **Trust:** Corporate footer with legal disclaimer
Level 3	**Targets:** Password Manager, VPN Client, Admin Portal / **Actions:** Disconnect Network, Report to IT, Reset Passwords, Check Logs
Level 4	1. Deploy Keylogger → 2. Bypass Security Filters → 3. Capture Admin Credentials → 4. Exfiltrate Data
Level 5	**Customer Database:** Confidential + Encryption / **HR Records:** Confidential + Access Control / **Financial Forecast:** Confidential + Multi-Factor Auth / **Product Roadmap:** Internal + Activity Monitoring / **Press Releases:** Public + Activity Monitoring To pass this level, the player needs to get 4 out of 5 answers correctly.

Resources

A complete guide to domain spoofing - Resilience. (2025, July 23). Resilience. https://cyberresilience.com/threatonomics/comple-guide-to-domain-spoofing/#:~:text=Domain%20spoofing%20is%20a%20cyberattack,domain%20name%20to%20deceive%20users.

Advantex Network Solutions Limited. (2025, August 13). *What is Trojan Malware? Definition and Examples*. https://www.advantex.uk.com/trojan-malware/#:~:text=Trojan%20malware%20hides%20itself%20in,the%20Trojan's%20purpose%20and%20function.

Backdoor. (n.d.). Secuinfra. https://www.secuinfra.com/en/glossary/backdoor/

Cybersecurity: Social engineering. (2025). Council of the European Union. https://www.consilium.europa.eu/en/policies/cybersecurity-social-engineering/

GeeksforGeeks. (2025, August 28). *What is a Dictionary Attack?* GeeksforGeeks. https://www.geeksforgeeks.org/computer-networks/what-is-a-dictionary-attack/

JumpCloud. (2025, April 22). What are Dictionary Attacks? - JumpCloud. https://jumpcloud.com/it-index/what-are-dictionary-attacks

Network security logging and monitoring - ITSAP.80.085 - Canadian Centre for Cyber Security. (2022, December 22). Canadian Centre for Cyber Security. https://www.cyber.gc.ca/en/guidance/network-security-logging-monitoring-itsap80085

Keylogger. (n.d.). Secuinfra. https://www.secuinfra.com/en/glossary/keylogger/

NordPass. (n.d.). What is password hashing? https://nordpass.com/blog/password-hash/

Privilege escalation attacks & how to defend against them | ScreenConnect. (n.d.). ScreenConnect. https://www.screenconnect.com/blog/privilege-escalation-attacks-how-to-defend-against-them#:~:text=A%20privilege%20escalation%20attack%20is,an%20all%2Daccess%20administrative%20pass.

Scarfone, K., Souppaya, M., Cody, A., Orebaugh, A., & National Institute of Standards and Technology. (2008). Technical Guide to Information Security Testing and Assessment. In NIST Special Publication 800-115. National Institute of Standards and Technology. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf

Trojans: how can I identify malware in disguise? (n.d.). Federal Office for Information Security. https://www.bsi.bund.de/EN/Themen/Verbraucherinnen-und-Verbraucher/Cyber-Sicherheitslage/Methoden-der-Cyber-Kriminalitaet/Schadprogramme/Trojaner/trojaner_node.html

What is data exfiltration? | Bitwarden. (n.d.). Bitwarden. https://bitwarden.com/resources/what-is-data-exfiltration/

What is password hashing? | Bitwarden. (n.d.). Bitwarden. https://bitwarden.com/resources/what-is-password-hashing/